Top Defects

CSE 360 HW3 - Task 2.1 - Lessons Learned System (TP2)

This document sorts the 2025 CWE Top 25 Most Dangerous Software Weaknesses and the OWASP Top 10:2025 into items that are relevant and irrelevant to our team's Java/JavaFX Lessons Learned system (H2 database, user accounts, roles, lessons, AI coaching). Relevant items are divided across the team. Sources: cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html and owasp.org/Top10/2025/.
Team: Elijah, Ronald, Hung, Rohan

1. Relevant Items (18) - 5 / 5 / 4 / 4 split

Item	Why it is relevant to our system	Team member
CWE-200 Exposure of Sensitive Information to an Unauthorized Actor	The app stores account details and lesson data; error messages, screens or queries could reveal them to the wrong user.	Elijah
A04:2025 Cryptographic Failures	Passwords and other sensitive data are saved in the database; if they are stored in plain text or weakly protected, a copy of the database exposes them.	Elijah
A08:2025 Software or Data Integrity Failures	Lesson and account data is trusted without checking it was not altered by someone who should not be able to change it.	Elijah
CWE-20 Improper Input Validation	Every text field (titles, bodies, categories, usernames) is user input; the validators are the first line of defense.	Elijah
A09:2025 Security Logging and Alerting Failures	Without logs of failed logins, deletes and edits, tampering or attacks cannot be noticed or investigated.	Elijah
CWE-89 SQL Injection and A05:2025 Injection	User text is used in H2 database operations for lessons and accounts; unsafe query building lets input change the query.	Ronald
A06:2025 Insecure Design	Security must be designed in (roles, data flow, limits); design gaps cannot be fixed by testing alone.	Ronald
A02:2025 Security Misconfiguration	Database setup, default accounts and settings in the project could be left insecure.	Ronald
A03:2025 Software Supply Chain Failures	The project depends on outside libraries (JavaFX, H2); a vulnerable or tampered library affects the whole app.	Ronald
CWE-770 Allocation of Resources Without Limits or Throttling	Unbounded lesson counts, input sizes or AI requests could slow or crash the app.	Ronald
A01:2025 Broken Access Control and CWE-284 Improper Access Control	Students, staff and curators have different permissions; users must not reach functions outside their role.	Hung
CWE-862 Missing Authorization	Actions such as edit, delete and lock must check that the user is allowed to perform them.	Hung
CWE-863 Incorrect Authorization	A check that exists but is wrong (e.g., wrong role comparison) gives users power they should not have.	Hung
CWE-639 Authorization Bypass Through User-Controlled Key	Lessons are found by id and linked to authorId; changing an id must not give access to another user's lesson.	Hung

Item	Why it is relevant to our system	Team member
CWE-306 Missing Authentication for Critical Function	Creating, editing, deleting and staff-only functions must require a logged-in user.	Rohan
A07:2025 Authentication Failures	Login, password rules and account setup protect every other feature.	Rohan
CWE-476 NULL Pointer Dereference	Java NullPointerExceptions from missing objects or empty fields can crash the app or skip checks.	Rohan
A10:2025 Mishandling of Exceptional Conditions	Errors and exceptions must fail safely without crashing or leaking internal details.	Rohan

2. Irrelevant Items

Item	Why the team considers it irrelevant
CWE-79 Cross-site Scripting	The app is a desktop JavaFX program; it does not generate web pages for a browser.
CWE-352 Cross-Site Request Forgery	There are no browser sessions or web requests for an attacker to forge.
CWE-787 Out-of-bounds Write; CWE-125 Out-of-bounds Read	Java checks array bounds and throws an exception; we cover those exceptions under A10 and boundary tests.
CWE-416 Use After Free	Java manages memory automatically; there is no manual freeing.
CWE-120, CWE-121, CWE-122 Buffer Overflows (classic, stack, heap)	Java strings and arrays cannot overflow into adjacent memory.
CWE-77 Command Injection; CWE-78 OS Command Injection	The app does not run operating system commands.
CWE-94 Code Injection	The app does not evaluate user-supplied code.
CWE-502 Deserialization of Untrusted Data	The app does not deserialize objects from outside sources.
CWE-22 Path Traversal	Users do not provide file paths; the app does not read or write user-named files.
CWE-434 Unrestricted Upload of File with Dangerous Type	The app has no file upload feature.
CWE-918 Server-Side Request Forgery	The AI feature calls a fixed service; users never provide URLs.

All ten OWASP Top 10:2025 categories are relevant. All 25 CWE Top 25 items are accounted for: 10 relevant (CWE-20, 89, 200, 284, 306, 476, 639, 770, 862, 863) and 15 irrelevant.